COMPTIA SECURITY+ SY0-701 | DOMÍNIO 5 · GESTÃO DE PROGRAMA DE SEGURANÇA E GOVERNANÇA (20%)

Security+ 5.1 · Security Procedures

Mestre CyberSec · **Aula 5.1 — Security Procedures** (7:02) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

> **Resumo Executivo da Aula:** Procedure: operacional — onboarding (criar conta/acesso), offboarding (Desativar, revogar, coletar equipamento — o esquecido gera ORPHAN account); resposta a phishing; reset de senha.

💡 Highlights que a prova CompTIA cobra

- Offboarding: desativa conta, revoga acesso — o esquecido gera ORPHAN
- Orphan account = conta sem dono após offboarding falho — risco alto

🎯 Dicas de Prova & Cenários Típicos da Banca

- 'process when employee leaves the company'=offboarding

🧯 Além do Vídeo: Conceitos Oficiais, Siglas e Armadilhas (Seção 5.1 — Security Procedures)

Por que este aprofundamento é cobrado na prova?: O vídeo resume os tópicos práticos, mas o exame CompTIA SY0-701 cobra discernimento técnico rigoroso sobre as tecnologias e protocolos específicos desta seção:

• Integração/Onboarding (N/A)
Procedimento operacional para conceder a um novo funcionário contas, acessos e equipamentos necessários à função, seguindo o menor privilégio.

⚠ ***Armadilha CompTIA:*** *Prova: 'new employee access' ou 'criar conta/acesso' = onboarding. Não confunda com offboarding.*

• Desligamento/Offboarding (N/A)
Procedimento operacional para desativar contas, revogar acessos e recolher equipamentos quando um funcionário sai; falha gera contas órfãs.

⚠ ***Armadilha CompTIA:*** *Gatilho clássico: 'process when employee leaves the company' = offboarding. Inclui desativar/revogar/coletar, não apenas deletar conta.*

• Conta Órfã (N/A)
Conta ativa que fica sem proprietário após offboarding falho ou remoção de conta não realizada, criando risco de acesso não autorizado.

⚠ ***Armadilha CompTIA:*** *Palavra-chave: conta esquecida após desligamento = orphan account. É risco alto; deve ser desativada/removida imediatamente.*

• Provisionamento de Conta (N/A)
Processo de criar, gerenciar e atribuir contas de usuário e permissões, normalmente durante onboarding e mudanças de função.

⚠ ***Armadilha CompTIA:*** *Diferença: provisioning concede acesso; deprovisioning/offboarding remove. Onboarding normalmente usa provisioning com menor privilégio.*

• Revogação de Acesso (N/A)
Ato de remover ou desativar permissões, tokens e sessões de um usuário para que ele não acesse mais recursos após offboarding ou mudança de função.

⚠ ***Armadilha CompTIA:*** *Prova: offboarding exige revogar acesso, não só desativar conta; sessões ativas e credenciais também devem ser invalidadas.*

• Resposta a Phishing (N/A)

Procedimento documentado para reportar, conter e analisar mensagens suspeitas de phishing para evitar roubo de credenciais e propagação de malware.

⚠️ ***Armadilha CompTIA:*** *Gatilho: usuário recebe e-mail suspeito; a primeira ação segura é reportar ao time de segurança, não clicar, responder ou abrir anexo.*

• Redefinição de Senha (N/A)

Procedimento de segurança para verificar a identidade e permitir que um usuário defina uma nova senha após esquecimento ou comprometimento da credencial.

⚠️ ***Armadilha CompTIA:*** *Prova: reset de senha exige verificação de identidade; não envie senha por e-mail. MFA e perguntas de segurança podem ser usados na verificação.*

• Procedimento Operacional Padrão (SOP)

Conjunto documentado e repetível de etapas para operações de segurança rotineiras, como onboarding, offboarding, resposta a phishing e reset de senha.

⚠️ ***Armadilha CompTIA:*** *Conceito guarda-chuva: procedimentos operacionais de segurança devem ser documentados, seguidos e revisados; não são opcionais.*

✅ Perguntas de Treino Comentadas (10 Questões de Cenários Reais)

Cenários autênticos alinhados aos objetivos do exame. O gabarito com análise completa dos distratores encontra-se ao final.

QUESTÃO 1 · CENÁRIO DE EXAME

Um gerente de contratação pede verbalmente ao service desk que crie uma conta para um novo funcionário e conceda acesso à pasta compartilhada de finanças. O RH ainda não concluiu o registro de onboarding, e o service desk não tem aprovação escrita do proprietário do sistema. Qual ação segue melhor o procedimento de onboarding?

A) Criar a conta imediatamente e conceder acesso a finanças porque o gerente aprovou verbalmente.

B) Criar a conta apenas com acesso padrão e adicionar acesso a finanças após uma solicitação formal autorizada ser aprovada.

C) Criar a conta sob uma conta compartilhada temporária de finanças até o RH concluir o registro.

D) Criar a conta e enviar a senha inicial para o endereço pessoal do funcionário.

QUESTÃO 2 · CENÁRIO DE EXAME

A equipe de segurança recebe aviso de que um funcionário foi desligado com efeito imediato. O funcionário tem conta VPN ativa, conta de e-mail e tokens de aplicativos em nuvem. De acordo com o procedimento de offboarding, qual ação deve ser realizada primeiro?

A) Excluir a conta e todos os dados associados imediatamente.

B) Desativar a conta e revogar sessões e tokens ativos.

C) Redefinir a senha e aguardar o gerente confirmar o desligamento.

D) Transferir a caixa de correio para o gerente antes de desativar a conta.

QUESTÃO 3 · CENÁRIO DE EXAME

Durante uma revisão trimestral de acessos, um auditor encontra uma conta de domínio ativa pertencente a um contratado que deixou a empresa há seis meses. Nenhum gerente é responsável pela conta, e ela ainda está habilitada. Qual termo descreve essa conta?

A) Conta de serviço

B) Conta compartilhada

C) Conta privilegiada

D) Conta órfã

QUESTÃO 4 · CENÁRIO DE EXAME

Um usuário recebe um e-mail alegando que sua senha expirará e pedindo que clique em um link para redefini-la. O usuário reporta o e-mail ao service desk sem clicar no link. De acordo com o procedimento de resposta a phishing, o que o service desk deve fazer primeiro?

A) Instruir o usuário a não interagir com a mensagem, preservar o e-mail e escalá-lo para a equipe de segurança.

B) Encaminhar o e-mail para todos os funcionários para que fiquem atentos a mensagens semelhantes.

C) Dizer ao usuário para excluir o e-mail e continuar trabalhando normalmente.

D) Redefinir a senha do usuário imediatamente e encerrar o chamado.

QUESTÃO 5 · CENÁRIO DE EXAME

Um agente do help desk recebe uma ligação de alguém solicitando redefinição de senha. O solicitante sabe o nome de usuário e o nome do gerente, mas não consegue fornecer a matrícula nem responder às perguntas de verificação aprovadas. O que o agente deve fazer de acordo com o procedimento de redefinição de senha?

A) Redefinir a senha para um valor temporário e enviá-la para o e-mail pessoal do solicitante.

B) Pedir ao solicitante a senha atual para verificar a identidade.

C) Desativar o MFA da conta para que o solicitante possa usar a redefinição autônoma.

D) Seguir o processo aprovado de verificação de identidade; se a verificação falhar, não redefinir e escalar a solicitação.

QUESTÃO 6 · CENÁRIO DE EXAME

A conta de um funcionário foi desativada no último dia de trabalho, mas o notebook corporativo nunca foi devolvido. Qual controle adicional de offboarding mitiga melhor o risco de exposição de dados do dispositivo ausente?

A) Alterar todas as senhas de domínio da organização.

B) Excluir a caixa de correio do ex-funcionário.

C) Apagar remotamente o notebook e rastrear a devolução do ativo por meio da lista de verificação de offboarding.

D) Desativar o token MFA do ex-funcionário.

QUESTÃO 7 · CENÁRIO DE EXAME

Um analista de segurança confirma que um e-mail reportado contém um link malicioso e foi entregue a várias caixas de correio de funcionários. Qual ação segue melhor o procedimento de contenção de phishing?

A) Enviar um alerta para toda a organização sobre a mensagem.

B) Redefinir as senhas de todos os funcionários que receberam o e-mail.

C) Colocar a mensagem em quarentena em todas as caixas de correio e bloquear o remetente e a URL.

D) Pedir aos destinatários que encaminhem o e-mail para a equipe de segurança para rastreamento.

QUESTÃO 8 · CENÁRIO DE EXAME

Um gerente solicita acesso de administrador de domínio para um novo funcionário de marketing 'para projetos futuros'. O procedimento de onboarding exige provisionamento baseado em função e privilégio mínimo. O que o administrador de segurança deve fazer?

A) Conceder acesso de administrador de domínio temporariamente e revisar após 90 dias.

B) Conceder acesso de administrador de domínio, mas exigir MFA para a conta.

C) Criar a conta sob uma credencial compartilhada de administrador de marketing existente.

D) Negar a solicitação e provisionar apenas o acesso padrão da função de marketing; exigir justificativa e aprovação separadas para qualquer acesso privilegiado.

QUESTÃO 9 · CENÁRIO DE EXAME

Um usuário relata um login VPN não autorizado de outro país enquanto a conta ainda está ativa. Qual ação segue melhor o procedimento de comprometimento de conta?

A) Desativar a conta e revogar sessões e tokens ativos, depois redefinir as credenciais.

B) Redefinir a senha somente depois que o usuário retornar ao escritório.

C) Aumentar os requisitos de complexidade de senha e continuar monitorando.

D) Excluir a caixa de correio do usuário e o perfil VPN.

QUESTÃO 10 · CENÁRIO DE EXAME

Uma organização descobre repetidamente contas órfãs porque as notificações do RH sobre funcionários desligados são atrasadas. Qual controle no procedimento operacional padrão de offboarding previne melhor esse problema?

A) Exigir treinamento anual de conscientização de segurança para todos os funcionários.

B) Impor expiração trimestral de senha para todas as contas de usuário.

C) Integrar o desprovisionamento automatizado às mudanças de status do RH, para que a desativação da conta seja acionada quando o vínculo terminar.

D) Executar simulações diárias de phishing para a equipe de segurança.

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

Questão 1: Alternativa B — Criar a conta apenas com acesso padrão e adicionar acesso a finanças após uma solicitação formal autorizada ser aprovada.

Procedimentos de onboarding exigem autorização verificada e provisionamento baseado em função, com privilégio mínimo. Uma solicitação verbal não é suficiente para acesso sensível. O service desk deve criar apenas a conta padrão aprovada e depois exigir solicitação formal e aprovação antes de conceder acesso a finanças. Contas compartilhadas e envio de credenciais para e-mail pessoal violam a política de segurança.

Questão 2: Alternativa B — Desativar a conta e revogar sessões e tokens ativos.

A primeira prioridade no offboarding é interromper o acesso. Desativar a conta e revogar sessões/tokens ativos imediatamente impede que o ex-funcionário use credenciais existentes. Excluir dados ou transferir a caixa de correio antes de desativar pode criar risco ou destruir evidências. Apenas redefinir a senha pode não encerrar sessões já ativas.

Questão 3: Alternativa D — Conta órfã

Uma conta órfã é uma conta ativa que não tem mais proprietário válido ou necessidade de negócio, frequentemente porque o offboarding foi incompleto. Ela deve ser revisada, desativada e removida de acordo com os requisitos de retenção. Contas de serviço, compartilhadas e privilegiadas têm definições e controles diferentes.

Questão 4: Alternativa A — Instruir o usuário a não interagir com a mensagem, preservar o e-mail e escalá-lo para a equipe de segurança.

O procedimento de resposta a phishing exige conter o relato e escalá-lo para a equipe de segurança para análise. O usuário não deve interagir com a mensagem, e o e-mail original deve ser preservado para investigação. Encaminhar em massa pode espalhar o phishing, excluir destrói evidências, e redefinir senha só é necessário se credenciais foram inseridas.

Questão 5: Alternativa D — Seguir o processo aprovado de verificação de identidade; se a verificação falhar, não redefinir e escalar a solicitação.

Procedimentos de redefinição de senha exigem verificação forte de identidade antes de alterar credenciais. Conhecer o nome de usuário ou o nome do gerente não é suficiente. Se o solicitante não conseguir satisfazer a verificação, o agente deve recusar a redefinição e escalar. Enviar credenciais para e-mail pessoal, pedir a senha antiga ou desativar MFA enfraquece a segurança.

Questão 6: Alternativa C — Apagar remotamente o notebook e rastrear a devolução do ativo por meio da lista de verificação de offboarding.

O offboarding inclui coletar ou apagar remotamente ativos da empresa. Um notebook ausente pode expor dados armazenados localmente, credenciais em cache ou configurações de VPN. Apagar remotamente e rastrear o ativo aborda diretamente esse risco. Alterações de senha em todo o domínio, exclusão de caixa de correio e desativação de token MFA não controlam o endpoint ausente.

Questão 7: Alternativa C — Colocar a mensagem em quarentena em todas as caixas de correio e bloquear o remetente e a URL.

A contenção visa impedir que a ameaça se espalhe ou seja acessada. Colocar a mensagem em quarentena em todas as caixas de correio e bloquear remetente/URL impede novos cliques e entregas. Alertas e encaminhamento são úteis depois, mas não contêm o e-mail malicioso. Redefinições em massa de senha não são indicadas a menos que credenciais tenham sido comprometidas.

Questão 8: Alternativa D — Negar a solicitação e provisionar apenas o acesso padrão da função de marketing; exigir justificativa e aprovação separadas para qualquer acesso privilegiado.

O onboarding deve seguir o privilégio mínimo e o controle de acesso baseado em função. Acesso de administrador de domínio não se justifica por projetos futuros e não deve ser concedido por padrão. O administrador deve negar a solicitação, provisionar a função padrão e exigir uma solicitação separada aprovada para acesso privilegiado. Concessões temporárias, apenas MFA ou credenciais administrativas compartilhadas não corrigem privilégio excessivo.

Questão 9: Alternativa A — Desativar a conta e revogar sessões e tokens ativos, depois redefinir as credenciais.

Quando uma conta é suspeita de comprometimento, o procedimento deve conter o incidente primeiro. Desativar a conta e revogar sessões/tokens ativos impede que o atacante continue usando o acesso existente. A redefinição de credenciais vem após a contenção. Esperar, apenas aumentar a complexidade ou excluir caixa de correio/perfil VPN não encerra prontamente o acesso não autorizado.

Questão 10: Alternativa C — Integrar o desprovisionamento automatizado às mudanças de status do RH, para que a desativação da conta seja acionada quando o vínculo terminar.

Contas órfãs geralmente resultam de offboarding atrasado ou não realizado. Automatizar o desprovisionamento com base em mudanças de status do RH reduz atrasos humanos e garante que as contas sejam desativadas quando o vínculo terminar. Treinamento de conscientização, expiração de senha e simulações de phishing não previnem diretamente contas órfãs.